Práctica de laboratorio: Ataque a una base de datos mySQL

Objetivos

En esta práctica de laboratorio verán un archivo PCAP de un ataque anterior a una base de datos SQL.

Antecedentes / Escenario

Los ataques de inyección SQL permiten a un ciberatacante ejecutar sentencias SQL en un sitio web y recibir una respuesta de la base de datos. Esto les permite modificar los datos actuales de la base de datos, suplantar identidades y ejecutar malware variado.

Hemos creado un archivo PCAP para que vean un ataque anterior a una base de datos SQL. En esta práctica de laboratorio verán los ataques a la base de datos SQL y responderán las preguntas.

Recursos necesarios

- Máquina virtual CyberOps Workstation
- Acceso a Internet

Parte 1: Abrir el archivo PCAP y seguir al atacante de la base de datos SQL

Utilizarán Wireshark para analizar el tráfico de red. Después de iniciar Wireshark, abrirán una captura de red ya guardada y verán un ataque de inyección SQL, paso a paso, contra una base de datos SQL.

Paso 1: Abrir Wireshark y cargar el archivo PCAP.

La aplicación Wireshark se puede abrir por medio de diversos métodos en una estación de trabajo de Linux.

a. Iniciar la VM CyberOps Workstation y ejecutar Wireshark.

b. Con Wireshark, abrir **/home/analyst/lab.support.files/SQL_Lab.pcap**

c. El archivo PCAP contiene el tráfico de red capturado. Esta captura se extiende por un período de 8 minutos (441 segundos): la duración de este ataque de inyección SQL. Puede validar esto en la columna Time.

En función de la información que muestra Wireshark

¿ cuáles son las dos direcciones IP involucradas en este ataque de inyección SQL ?

Paso 2: Ver el ataque de inyección SQL

En este paso se podrá visualizar el comienzo de un ataque.

a. Dentro de la captura de Wireshark, hagan clic derecho sobre la línea 13 y seleccionen **Follow HTTP Stream**. Se eligió la línea 13 porque es una solicitud GET HTTP. Esto será muy útil para seguir el flujo de datos a medida que lo ven las capas de aplicación y se genera una prueba de consulta para la inyección SQL.

   El tráfico de origen se muestra en rojo. El origen ha enviado una solicitud GET al host 10.0.2.15. En color azul, el dispositivo de destino le está respondiendo al origen.

b. Hagan clic en **Find** e introduzcan 1=1. Busquen esta entrada. Cuando se encuentre el texto, hagan clic en **Cancel** en el cuadro de búsqueda de texto Find. La cadena 1=1.

c. El atacante ha ingresado una consulta (1=1) en un cuadro de búsqueda de UserID en el destino 10.0.2.15 para ver si la aplicación es vulnerable a la inyección SQL. En lugar de responder con un mensaje de falla en el inicio de sesión, la aplicación respondió con un registro de la base de datos. De este modo el atacante ha verificado que puede ingresar un comando SQL y que la base de datos le responderá. La cadena de búsqueda 1=1 crea una sentencia SQL que siempre será verdadera. En el ejemplo no importa lo que se haya ingresado en el campo, siempre será verdadera.

d. Cierren la ventana Follow HTTP Stream.

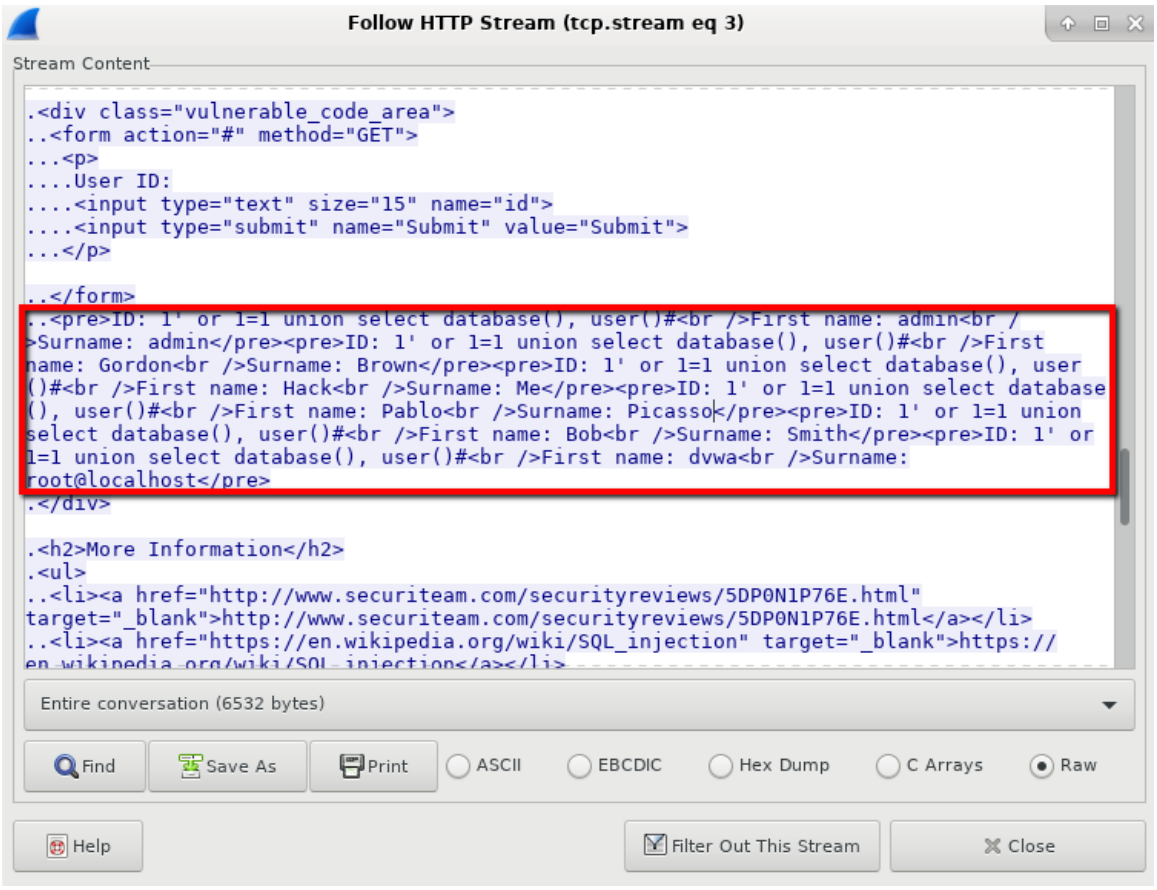
e. Hagan clic en **Clear** para mostrar toda la conversación de Wireshark.

Paso 3: El ataque de inyección SQL continúa...

En este paso visualizarán cómo prosigue el ataque.

a. Dentro de la captura de Wireshark, hagan clic derecho sobre la línea 19 y seleccionen **Follow HTTP Stream** (Seguir flujo de HTTP) y repita el **Find** de **1=1**. Luego cierre el cuadro de búsqueda.

b. El atacante ha ingresado una consulta (**1' or 1=1 union select database(), user()#**) en un cuadro de búsqueda de ID de usuario en el destino 10.0.2.15. En lugar de responder con un mensaje de falla en el inicio de sesión, la aplicación respondió con la siguiente información:



El nombre de la base de datos es **dvwa** y su usuario es **dvwa@localhost**. También se muestran varias cuentas de usuario.

c. Cerrar la ventana Follow HTTP Stream y borrar toda la conversación de Wireshark.

Paso 4: El ataque de inyección SQL proporciona información del sistema.

El atacante prosigue y comienza a buscar información más específica.

a. Dentro de la captura de Wireshark, hagan clic derecho sobre la línea 22 y seleccionen **Follow HTTP Stream** (Seguir flujo de HTTP) y repita el **Find** de **1=1**. Luego cierre el cuadro de búsqueda.

b. El atacante ha ingresado una consulta (**1' or 1=1 union select null, version ()#**) en un cuadro de búsqueda de ID de usuario en el destino 10.0.2.15 para localizar el identificador de la versión. Observe que es el identificador de versión se encuentra al final del resultado justo antes de **</pre>. ** cierre del código HTML.



¿ Cuál es la versión ?

c. Cierren la ventana Follow HTTP Stream.

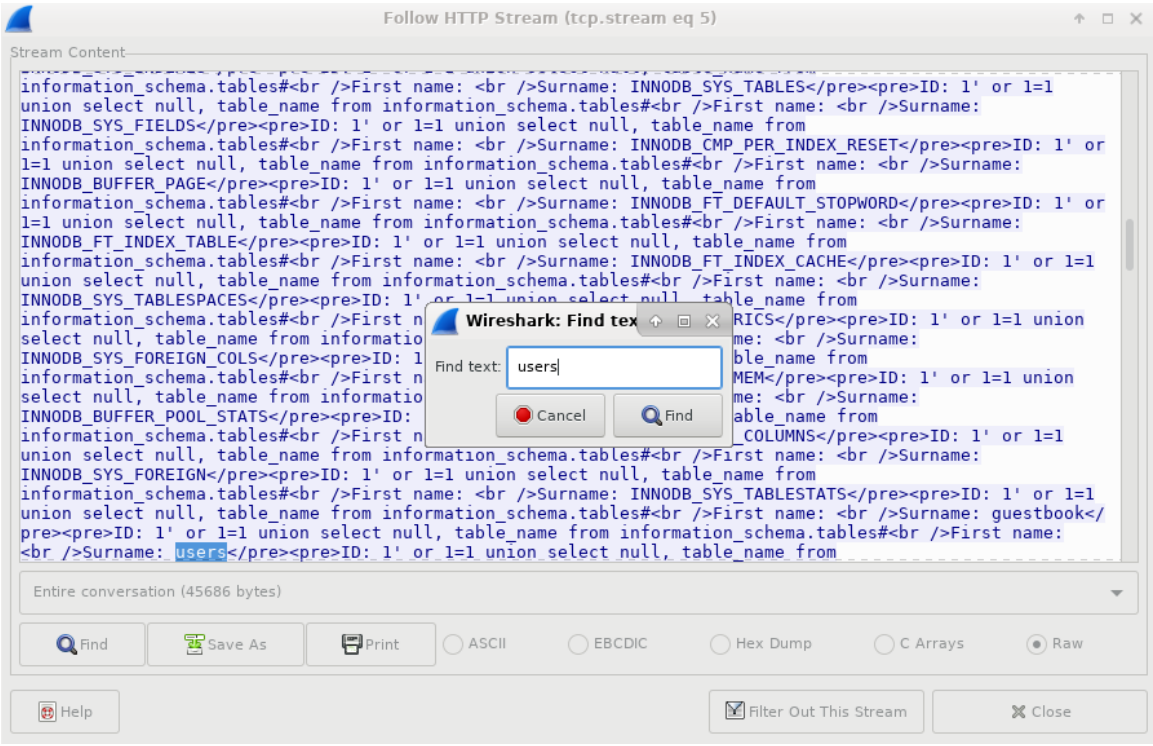
d. Hagan clic en **Clear** (Borrar) para mostrar toda la conversación de Wireshark.

Paso 5: El ataque de inyección SQL e información de tablas

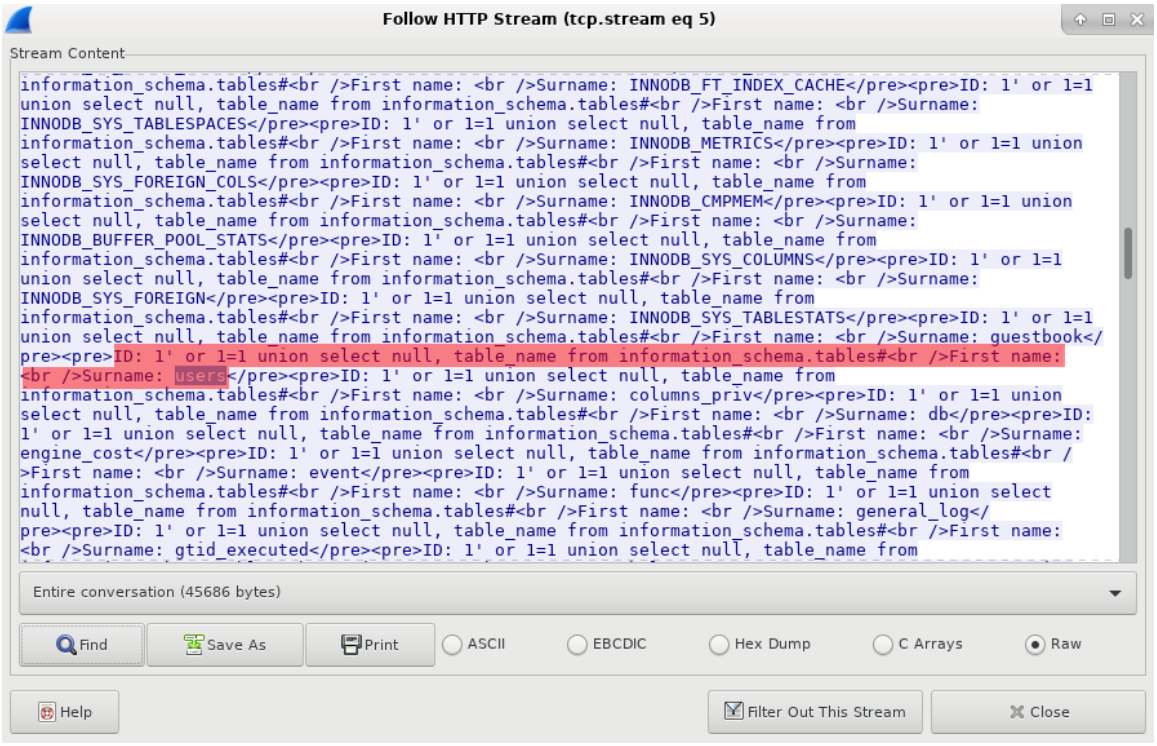
El atacante sabe que hay gran cantidad de tablas SQL repletas de información. Trata de encontrarlas.

a. Dentro de la captura de Wireshark, hagan clic derecho sobre la línea 25 y seleccionen **Follow HTTP Stream** (Seguir flujo de HTTP).

b. Haga clic en **Buscar** e introduzca **users**. Busquen la entrada que se muestra a continuación. Cuando se encuentre el texto, cerrar el cuadro de búsqueda de texto **Find**.



c. Ahora el atacante ha ingresado una consulta (**1' or 1=1 union select null, table_name from information_schema.tables#**) en un cuadro de búsqueda de ID de usuario en el destino 10.0.2.15 para ver todas las tablas de la base de datos. Esto proporciona una enorme salida de muchas tablas, ya que el atacante especificó "null" sin más especificaciones.



¿ Qué haría el comando modificado de (**1' OR 1=1 UNION SELECT null, column_name FROM INFORMATION_SCHEMA.columns WHERE table_name='users'**) por el atacante ?

d. Cerrar la ventana Follow HTTP Stream y borrar la conversación de Wireshark.

Paso 6: El ataque de inyección SQL concluye

El ataque finaliza con el mejor premio posible: hashes de contraseñas.

a. Dentro de la captura de Wireshark, hagan clic derecho sobre la línea 28 y seleccionen **Follow HTTP Stream** (Seguir flujo de HTTP) y repita el **Find** de **1=1**. Luego cierre el cuadro de búsqueda.

¡ En este caso el atacante ha ingresado una consulta (**1' or 1=1 union select user, password from users#**) en un cuadro de búsqueda de ID de usuario en el destino 10.0.2.15 para obtener nombres de usuario y hashes de contraseñas !



¿ Qué usuario tiene 8d3533d75ae2c3966d7e0d4fcc69216b como hash de su contraseña ?

Utilizar el sitio web https://crackstation.net/ para copiar el hash de la contraseña en el decodificador de hashes de contraseñas y comiencen a decodificarlo.

¿Cuál es la contraseña en texto plano?

b. Cierren la ventana Follow HTTP Stream. Cierren todas las ventanas abiertas.

Entregable

1. ¿Cuál es el riesgo de hacer que las plataformas utilicen el lenguaje SQL?
2. Buscar en internet "**evitar ataques de inyección SQL**" ó "**Inyección SQL INCIBE**" ó "**SQL Injection OWASP**", analizar la información y luego mencionar al menos tres métodos o pasos que se pueden utilizar para evitar ataques de inyección SQL.

Cisco y/o sus filiales. Todos los derechos reservados. Información confidencial de Cisco